Beacon Incident — Walkthrough

WORKING DRAFT. Figures and factual scaffolding (captions, citations, timeline, flag recovery) are filled in. Every **[AUTHOR: ...]** block is yours to write in your own words before submitting — OffSec does not accept AI-written Grimoire walkthroughs. Delete this banner and the final "Author-only" appendix before exporting the version you submit.

Lab: Beacon Incident (Grimoire, defensive) · **Difficulty:** Intermediate · **Flags:** 2 × `OS{…}`
Environment: Northwind Trading · host `FIN-WKS-07` · user `NORTHWIND\j.morgan` · C2 `cdn.lifestyle-deals.net` (203.0.113.45).

1. Scenario & scope

> [AUTHOR: 2–4 sentences — what alerted, which host/user, and what you are asked to determine. Use only the provided evidence.]

2. Evidence inventory

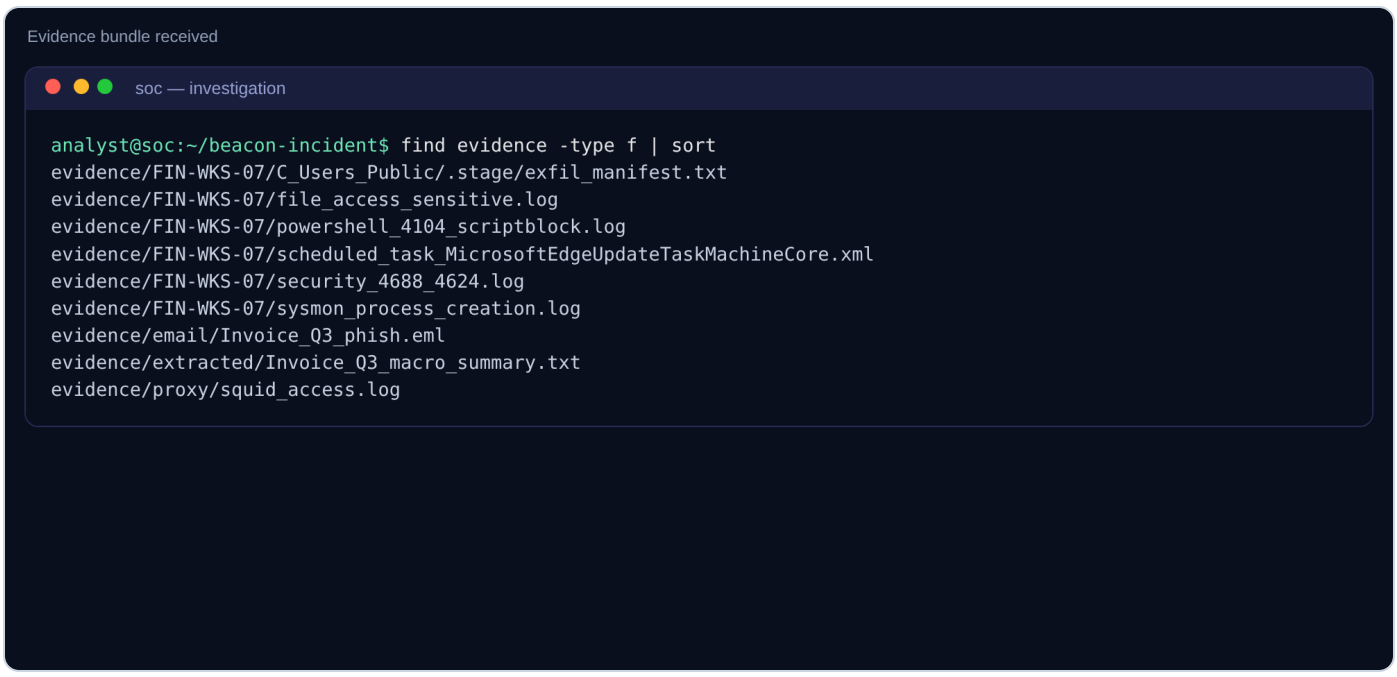


Fig 1 — the triage bundle: email, Sysmon, PowerShell 4104, Security 4688/4624, scheduled task, EDR file-access, and proxy logs.

> [AUTHOR: one line on your triage order and why.]

3. Delivery & initial execution

Phishing email — spoofed sender, SPF/DMARC fail

soc — investigation

```
analyst@soc:~/beacon-incident$ sed -n '1,9p' evidence/email/Invoice_Q3_phish.eml
Return-Path: <billing@vendor-portal-support.com>
Received: from mail.vendor-portal-support.com ([198.51.100.23])
        by mx.northwind.local; 2026-10-03 09:11:04 +0000
Authentication-Results: mx.northwind.local; spf=fail; dkim=none; dmarc=fail
From: Vendor Billing <billing@vendor-portal-support.com>
To: <j.morgan@northwind.local>
Subject: OVERDUE Invoice Q3 - immediate payment required
Date: 2026-10-03 09:11:03 +0000
Content-Type: multipart/mixed; boundary="b1"
```

Fig 2 — the phishing email: spoofed sender, SPF/DMARC fail, macro-enabled attachment.

Static triage of the attached macro (defanged)

soc — investigation

```
analyst@soc:~/beacon-incident$ sed -E 's/-enc [A-Za-z0-9+/=]+/-enc <BASE64>/'
evidence/extracted/Invoice_Q3_macro_summary.txt
Static triage of the attached document's VBA project (olevba summary):

  Module: ThisDocument
  AutoExec: Document_Open  (runs automatically when the document opens)
  Suspicious: builds a command string and calls Shell(...) with vbHide
  Suspicious: launches powershell with '-nop -w hidden -enc <Base64>'

The exact encoded value as launched (see Sysmon / 4104 for full context):
  powershell -nop -w hidden -enc <BASE64>

(The document's full macro body is not reproduced here; the behavioural
 indicators above are what matters for detection.)
```

Fig 3 — static triage of the macro: Document_Open launches hidden encoded PowerShell.

Sysmon EID 1 — WINWORD spawns encoded PowerShell, then schtasks

soc — investigation

```
analyst@soc:~/beacon-incident$ sed -E 's/-enc [A-Za-z0-9+/=]+/-enc <BASE64>/g' evidence/FIN-WKS-
07/sysmon_process_creation.log | cut -c1-150
2026-10-03 09:14:52 EID=1 User=NORTHWIND\j.morgan Image=C:\Program Files\Microsoft Office\root\Office16\WINWORD.EX
E ParentImage=C:\Windows\explorer.ex
2026-10-03 09:15:03 EID=1 User=NORTHWIND\j.morgan Image=C:\Windows\System32\cmd.exe ParentImage=C:\Program Files\M
icrosoft Office\root\Office16\WINWOR
2026-10-03 09:15:03 EID=1 User=NORTHWIND\j.morgan Image=C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentImage=C:\Windows\System32\cmd.
2026-10-03 09:16:40 EID=1 User=NORTHWIND\j.morgan Image=C:\Windows\System32\schtasks.exe ParentImage=powershell.ex
e CommandLine="schtasks /create /tn
2026-10-03 09:18:30 EID=1 User=NORTHWIND\j.morgan Image=powershell.exe ParentImage=powershell.exe CommandLine="pow
```

Fig 4 — Sysmon EID 1: WINWORD → cmd → powershell -enc, then schtasks.

> [AUTHOR: explain the lure and the authentication failures, then the process tree — Office spawning cmd/powershell with `-enc -w hidden -nop`. Name the techniques (T1566.001, T1204.002, T1059.001).]

First flag

Decode the -enc value (Base64 UTF-16LE) → flag 1

soc — investigation

```
analyst@soc:~/beacon-incident$ B=$(grep -oE -- '-enc [A-Za-z0-9+/=]+' evidence/FIN-WKS-
07/sysmon_process_creation.log | head -1 | awk '{print $2}');...
# [IR note] encoded launcher recovered from script-block logging
# operational payload REDACTED for this training bundle
$marker = 'OS{m4cr0_enc_p0w3rsh3ll_dr0pp3r}'
# external host seen in proxy logs: cdn.lifestyle-deals.net
```

Fig 5 — decoding the -enc value (Base64 of UTF-16LE).

```
B=$(grep -oE -- '-enc [A-Za-z0-9+/=]+' evidence/FIN-WKS-07/sysmon_process_creation.log \
      | head -1 | awk '{print $2}')
python3 -c "import base64,sys;print(base64.b64decode(sys.argv[1]).decode('utf-16-le'))" "$B"
OS{m4cr0_enc_p0w3rsh3ll_dr0pp3r}
```

4. Command & control / second stage

PowerShell 4104 script-block logging

soc — investigation

```
analyst@soc:~/beacon-incident$ cat evidence/FIN-WKS-07/powershell_4104_scriptblock.log
2026-10-03 09:15:04 EventID=4104 Level=Warning ScriptBlockText=<<<
# [IR note] encoded launcher recovered from script-block logging
# operational payload REDACTED for this training bundle
$marker = 'OS{m4cr0_enc_p0w3rsh3ll_dr0pp3r}'
# external host seen in proxy logs: cdn.lifestyle-deals.net
>>>
2026-10-03 09:15:22 EventID=4104 Level=Warning ScriptBlockText=<<<
# second script block observed; body redacted in this training bundle.
# indicator: repeated outbound requests to http://cdn.lifestyle-deals.net/ (see proxy log)
>>>
```

Fig 6 — PowerShell 4104 script-block logging (decoded content; payload redacted in this bundle).

> [AUTHOR: explain what script-block logging revealed and the C2 indicator; tie it to the proxy evidence in §7. Techniques: T1027/T1140, T1105, T1071.001.]

5. Persistence

Persistence — scheduled task masquerading as an Edge update

soc — investigation

```
analyst@soc:~/beacon-incident$ sed -n '1,16p' evidence/FIN-WKS-
07/scheduled_task_MicrosoftEdgeUpdateTaskMachineCore.xml
<?xml version="1.0" encoding="UTF-16"?>
<Task version="1.4" xmlns="http://schemas.microsoft.com/windows/2004/02/mit/task">
  <RegistrationInfo>
    <Date>2026-10-03T09:16:40</Date>
    <Author>NORTHWIND\j.morgan</Author>
    <Description>Masquerades as a Microsoft Edge update task</Description>
  </RegistrationInfo>
  <Triggers><TimeTrigger><Repetition><Interval>PT10M</Interval></Repetition>
    <StartBoundary>2026-10-03T09:20:00</StartBoundary></TimeTrigger></Triggers>
  <Actions>
    <Exec>
      <Command>powershell.exe</Command>
      <Arguments>-nop -w hidden -ep bypass -File C:\Users\Public\x.ps1</Arguments>
    </Exec>
  </Actions>
</Task>
```

Fig 7 — scheduled task masquerading as a Microsoft Edge update, every 10 minutes.

> [AUTHOR: explain the scheduled-task persistence and the masquerading name (T1053.005, T1036.004).]

6. Credential access

EDR — powershell reads the browser credential store

soc — investigation

```
analyst@soc:~/beacon-incident$ cat evidence/FIN-WKS-07/file_access_sensitive.log
Sensitive file-access indicators (EDR):
2026-10-03 09:18:30 Process=powershell.exe Account=NORTHWIND\j.morgan Action=Read Path=C:\Users\j.morgan\AppData\L
ocal\Google\Chrome\User Data\Default\Login Data
2026-10-03 09:18:34 Process=powershell.exe Account=NORTHWIND\j.morgan Action=Read Path=C:\Users\j.morgan\AppData\L
ocal\Google\Chrome\User Data\Default\Network\Cookies
# unusual: powershell.exe reading the browser credential store
```

Fig 8 — EDR: powershell.exe reading the Chrome credential store (Login Data / cookies).

> [AUTHOR: explain why a non-browser process reading the browser credential store is suspicious (T1555.003).]

7. Collection & exfiltration

Proxy log — beacon + large upload to the C2 domain

soc — investigation

```
analyst@soc:~/beacon-incident$ cat evidence/proxy/squid_access.log
2026-10-03 09:15:20 10.50.12.37 GET http://cdn.lifestyle-deals.net/u/x.ps1 200 3488 "PowerShell"
2026-10-03 09:20:01 10.50.12.37 GET http://cdn.lifestyle-deals.net/api/task 200 12 "-"  (beacon)
2026-10-03 09:30:01 10.50.12.37 GET http://cdn.lifestyle-deals.net/api/task 200 12 "-"  (beacon)
2026-10-03 09:41:55 10.50.12.37 POST http://cdn.lifestyle-deals.net/api/upload 200 5242880 "-"  (large upload)
# cdn.lifestyle-deals.net resolves to 203.0.113.45; newly-registered, no business purpose
```

Fig 9 — proxy log: beacon GETs to /api/task and a 5 MB POST to /api/upload.

> [AUTHOR: explain the beaconing cadence and the large upload to the C2 domain (T1074.001 staging, T1041 exfil over C2).]

Second flag



Fig 10 — the staged exfil manifest left under C:\Users\Public\.stage.

```
cat evidence/FIN-WKS-07/C_Users_Public/.stage/exfil_manifest.txt
OS{br0ws3r_cr3ds_b34c0n_3xf1l}
```

8. Timeline (facts)

Time (UTC)	Event
09:11	phishing email delivered (SPF/DMARC fail)
09:14:52	user opens `Invoice_Q3.docm` (WINWORD)
09:15:03	WINWORD → cmd → `powershell -enc` (hidden)
09:15:20	second stage pulled from C2 (`GET /u/x.ps1`)
09:16:40	scheduled task persistence created
09:18:30	browser credential store accessed
09:20 → 09:41	beacon GETs; 5 MB POST upload to C2

9. Detections & lessons

> [AUTHOR: write your own recommendations. Ideas: alert on Office spawning cmd/powershell; `-enc -w hidden`; Script Block Logging + long Base64; `schtasks` from powershell + masquerading names; non-browser processes reading browser credential stores; beacon/large POST to newly-registered domains. See `artifacts.zip/mitre-attack.md`.]

Author-only appendix — DELETE before submitting

Reference answers (full citations in `artifacts.zip/answer-key.md`):
phish_sender = billing@vendor-portal-support.com · victim = FIN-WKS-07 / j.morgan · initial_exec = encoded PowerShell · flag1 = OS{m4cr0_enc_p0w3rsh3ll_dr0pp3r} · persistence = scheduled task · cred_access = browser credential store · c2_domain = cdn.lifestyle-deals.net · flag2 = OS{br0ws3r_cr3ds_b34c0n_3xf1l}